

Building Your Safe Hacking Lab

Unit 02 — Foundations

This week we build a place where it's safe to break things. The whole point: **our lab cannot reach anything it shouldn't.**



Gate: AUP first

**No hands-on work until your
Acceptable Use & Ethics
Agreement is signed — by you
and your guardian — and on
file.**

Learning objectives

By the end of this unit you can:

- **Explain** what a VM is and why pros use VMs and snapshots.
- **Describe** what Kali Linux is and why pentesters use it.
- **Compare** the three lab tiers and say which you're using and why.
- **Define** network isolation; explain host-only/internal vs. bridged/NAT.

Learning objectives (cont.)

- **Set up** your environment: Tier A AttackBox and/or Tier B VirtualBox + Kali.
- **Verify** isolation — reach the target but **not** the internet.
- **Take and restore** a snapshot (Tier B) or reset the environment (Tier A).
- **Document** your setup in the lab journal with screenshot proof.



The point this week

Isolation is how we keep "authorized" honest.

- We attack only pre-approved, intentionally-vulnerable targets.
- We **physically prevent** attacks from reaching anything else.
- Verifying isolation is an **ethical** step, not just a technical one.

Day 1 — Virtual machines, Kali & the AUP gate

Warm-up

"How would you safely test something dangerous without risking the real thing?"

Think: crash-test dummies. Flight simulators. A practice space you can wreck and reset.

What is a virtual machine?

A **VM** is a whole computer that runs as **software** inside your real computer.

Term	Meaning
Host	Your real, physical computer
Guest	A VM running on the host (e.g., Kali)
Hypervisor	The software that runs VMs (we use VirtualBox)

You can break a guest badly — and reset it in seconds.

Check your understanding

A virtual machine (VM) is best described as:

- A) A physical second computer
- B) A whole computer that runs as **software** inside your real one
- C) A web browser
- D) A type of virus

Answer

B — A whole computer that runs as software inside your real one.

- It's not extra hardware, a browser, or malware.
- That "software computer" is exactly what makes it safe to break.

One real machine can run several guests at once.

Check your understanding

Your real, physical computer is the ____, and a VM on it is the ____.
A) guest; host B) host; guest C) server; client D) target; attacker

Answer

B — host; guest.

- The **host** owns the hardware; the **guest** borrows a slice of it.
- The **hypervisor** is the software that hands out those slices.

Host = landlord, guest = tenant, hypervisor = the building manager.

Why pros use VMs

- **Safe to break:** mistakes stay inside the VM.
- **Easy to reset:** restore to a clean state instantly.
- **Isolated:** the VM's network can be sealed off from everything.

Never do attack practice on your real OS. Use a guest.

Check your understanding

Why do security pros work inside VMs? (Best answer.)

- A) VMs are faster than real computers
- B) You can safely break, isolate, and reset them
- C) VMs are required by law
- D) VMs can't run Linux

Answer

B — safely break, isolate, and reset them.

- Speed and the law are not the reason.
- The reset-to-clean superpower is the whole point.

A messed-up VM is a 10-second fix, not a disaster.

What is Kali Linux?

- A free **Linux distribution** (a version of Linux with bundled software).
- Loaded with security / pentesting **tools** out of the box.
- The standard **attack workstation** for pentesters.

Kali is the toolbox. The VM is the safe workshop we put it in.

Check your understanding

What is Kali Linux?

- A) A web browser
- B) A free Linux distro loaded with pentest tools — an attack workstation
- C) A type of firewall
- D) An antivirus program

Answer

B — a free Linux distro loaded with pentest tools.

- It's an operating system, not a browser or antivirus.
- "Attack workstation" = the machine a tester works **from**.

Remember Unit 01: the tools are dual-use. Authorization decides the rest.

Snapshots = an undo button

A **snapshot** is a saved, point-in-time copy of a VM you can instantly restore.

- Take one when the VM is clean and working.
- If the VM gets messed up or "owned" → **restore the snapshot.**
- Removes the fear of breaking things.

Snapshot vs. screenshot

- A **screenshot** is just a picture of your screen.
- A **snapshot** saves the VM's whole state — files and all.
- Take one when clean; restore it any time to rewind.

Like a video-game save point you can reload after a mistake.

Check your understanding

A **snapshot** lets you:

- A) Take a photo of your screen
- B) Save a VM's state and instantly restore it to a clean point
- C) Speed up the internet
- D) Permanently delete a VM

Answer

B — save a VM's state and instantly restore it.

- It's not a photo, a speed boost, or a delete button.
- This is your safety net all semester.

"When in doubt, restore the snapshot."

Day 1 exit ticket

"Name two reasons a security pro uses a VM instead of their real computer."

Journal: define **VM**, **host**, **guest**, **hypervisor**, **snapshot** in your own words.

Day 2 — The three lab tiers & why we isolate

The three lab tiers

Tier	What it is	Best when
A — Browser	TryHackMe / HTB AttackBox in your browser	Weak or locked-down machines; no install
B — Local VMs	VirtualBox + Kali + a target VM	You want full control
C — Wargames	picoCTF / OverTheWire (CTF, SSH)	Extra practice, later units

Know which tier(s) your class uses — and why.

What the AttackBox is

- A **browser Kali machine** you control from a web page.
- Already sandboxed and pre-authorized by the platform.
- No download, no BIOS settings, no isolation steps for you.

It's Kali in a tab — the platform handles the isolation.

Check your understanding

The TryHackMe **AttackBox** is:

- A) A physical computer you must buy
- B) An in-browser, pre-isolated attack machine — no install needed
- C) A malware sample
- D) A type of firewall

Answer

B — an in-browser, pre-isolated attack machine.

- You don't buy or install anything.
- The platform's targets are pre-authorized and sandboxed.

If it times out, just relaunch it — that's normal.

Check your understanding

Which is true about the three lab tiers?

- A) You must use all three
- B) Tier A needs only a browser; Tier B gives full control but more setup
- C) Tier C requires bridged networking
- D) Tier B has no isolation requirement

Answer

B — Tier A needs only a browser; Tier B gives full control.

- You don't have to use all three.
- **Every** local tier still requires isolation — no exceptions.

Choose the tier; never skip the isolation.

Network isolation: the big idea

Network isolation = keeping the lab on its own network so attacks can't reach the school LAN or the internet.

An un-isolated attack can **leak** onto the real network = **unauthorized access** = illegal.

Isolation is the technical proof behind your ethical promise.

Why isolation is ethical, not just technical

- A scan that "escapes" can hit real, off-limits machines.
- That's unauthorized access — a crime — even by accident.
- Isolation removes the chance to harm the wrong thing.

Promising not to is good. Making it impossible is better.

The four network modes

Mode	VM can reach...	Use for attacks?
Host-Only	Host + other lab VMs, not the internet	 Yes
Internal	Only other lab VMs (most isolated)	 Yes
NAT	The internet (through the host)	 No
Bridged	Straight onto the real network	 Never

Never bridged. Never NAT (during attacks).

- **Bridged** puts your VM directly on the real network — an attack could hit the school LAN.
- **NAT** gives the VM internet access — an attack could reach the open internet.
- Either one = **unauthorized access** waiting to happen.

The one allowed exception: temporarily switch to NAT to **update tools**, then switch back to host-only and **re-verify**.

Sort the adapter (guided practice)

For each scenario, pick host-only, internal, or NAT — and flag any that are dangerous:

- Attacking a target VM on the same network → **Host-Only / Internal**
- Two lab VMs that should never see the host → **Internal**
- Updating Kali's tools, supervised, then switching back → **NAT (temporary)**
- "I'll just bridge it, it's faster" →  **Dangerous — never**

Check your understanding

During an attack lab, which mode keeps the lab isolated?
A) Bridged B) NAT C) Host-Only (or Internal) D) Any of them

Answer

C — Host-Only (or Internal Network).

- Bridged and NAT both reach beyond the lab.
- Host-only and internal keep traffic sealed inside.

Attack mode = host-only or internal. Always.

Check your understanding

Which modes must you NOT use during an attack lab, and why?

- A) Host-Only and Internal — too slow
- B) Bridged and NAT — they break isolation (school LAN / internet)
- C) Internal and NAT — they cost money
- D) None; all modes are safe

Answer

B — Bridged and NAT break isolation.

- **Bridged** drops you onto the real school network.
- **NAT** opens a path to the internet.
- Either one means your attack could reach off-limits systems.

The "faster" excuse is exactly how accidents become crimes.

Day 2 exit ticket

"Which two network modes must you NOT use during an attack lab, and why?"

Journal: which tier(s) is our class using, and one sentence on why isolation matters.

Day 3 — Set up your environment



Say the reminder, confirm the gate

You may only run offensive techniques inside the approved, isolated lab — and only after your AUP is **signed by you and your guardian** and on file. Unauthorized access (even scanning) is illegal under the CFAA. **Minors are not exempt.**

Everyone confirms: **is your AUP signed?** If not, do the reading alternative.

Check your understanding

Before any hands-on work in this unit, you must have:

- A) A new laptop
- B) A signed Acceptable Use & Ethics Agreement on file
- C) A bridged network
- D) Admin rights to the school network

Answer

B — a signed Acceptable Use & Ethics Agreement on file.

- Signed by **you and your guardian** — no exceptions.
- No signature yet? You do the reading alternative.

The AUP is the door. No one walks in without it.

Tier A — Create your account

1. Go to the TryHackMe URL your teacher gives you (must be allowlisted by IT).
2. Create an account with school-appropriate details.
3. **Do not** reuse a personal password.



Screenshot: your logged-in dashboard (no password visible).

Tier A — Launch the AttackBox

1. Open the assigned intro room (e.g., *Intro to Cyber Security*).
2. Click **Start AttackBox** — wait for the split-screen to load.
3. The AttackBox is a **pre-isolated, sandboxed** machine in your browser — nothing to install.



Screenshot: the AttackBox loaded next to the room.

If the session times out, just relaunch it — that's normal.

Tier B — Import Kali into VirtualBox

Step 1 — Prerequisites: VirtualBox installed; **VT-x/AMD-V enabled in BIOS** (if Kali won't start or is painfully slow, this is usually why).

Step 2 — Import:

- VirtualBox → **File → Import Appliance**
- Choose the official Kali image your teacher staged → import
- Kali appears in your VM list.

Tier B — Set Kali to Host-Only

1. Select Kali → **Settings** → **Network**.
 2. Set **Adapter 1** → **Host-Only Adapter** (the host-only network your teacher created).
 3.  Do **not** select Bridged or NAT for attack labs.
 4. Click **OK**.
-  Screenshot: Network settings showing **Host-Only Adapter**.

Tier B — Boot Kali and find its IP

```
ip a
```

- Log in with the credentials your teacher provides (change the default password if instructed).
- Find Kali's host-only IP — often in the `192.168.56.x` range. **Write it in your journal.**

 Screenshot: the terminal showing Kali's IP.

Then start the **target VM** (e.g., Metasploitable 2) on the **same host-only network**.

Day 3 exit ticket

"What IP did your Kali (or AttackBox) get, and what network mode is it on?"

Day 4 — Verify isolation (the most important step)

Warm-up

*"How would you **prove** your lab can't reach the internet?"*

Predict before you test.

What `ping` actually does

- `ping` sends a tiny "are you there?" message to an address.
- If the address answers, you get **replies**.
- If nothing answers, the ping **times out**.

It's knocking on a door and listening for a knock back.

How isolation verification works

From your attack machine you should reach the **target** — but **not** any outside address.

Result	Meaning
Replies come back	You can reach that address
Times out / 100% loss	You cannot reach it

Here, failing to reach the internet is the **correct** result.

Tier B — Verify (step 1: reach the target)

```
ping -c 4 192.168.56.102 # your target's host-only IP
```

- **Expected:** replies come back — the ping **succeeds**.
- This proves Kali can reach the lab target on the isolated network.

 Screenshot the successful target ping.

Tier B — Verify (step 2: can't reach the internet)

```
ping -c 4 8.8.8.8
```

- **Expected:** the ping **fails / times out** (100% packet loss).
- **This failure is the correct, desired result** — your attacks cannot reach the internet.

  Screenshot the failed `8.8.8.8` ping.

  If `8.8.8.8` **succeeds**, STOP — your VM is NOT isolated. Check the adapter is Host-Only and tell your teacher before doing anything. 56

Check your understanding

`ping 8.8.8.8` from Kali during an attack lab. For a properly isolated lab, the correct result is:

- A) It succeeds (replies come back)
- B) It fails / times out — proving you can't reach the internet
- C) It restarts the VM
- D) It installs updates

Answer

B — it fails / times out.

- A reply from `8.8.8.8` would mean you can reach the internet.
- In an isolated lab, that reach should not exist.

Failure here is the win. Celebrate the timeout.

Check your understanding

You ping your lab **target's** host-only IP and it **succeeds**. This tells you:

- A) Your lab is broken
- B) Kali can reach the target on the isolated network — good
- C) You are connected to the internet
- D) The target is infected

Answer

B — Kali can reach the target on the isolated network.

- That's the half of isolation that should **work**.
- Target reachable + internet unreachable = correct setup.

You want a yes to the target and a no to the world.

Tier A — Verify

1. You're using the provided **AttackBox/sandbox** — already isolated and pre-authorized.
2. You may act **only** on the in-scope target the room provides — nothing else.
3. Confirm you're working inside the room's target, not any outside address.



Screenshot: the AttackBox + room confirming you're in the sandbox.

Day 4 exit ticket

*"Paste/describe the result of `ping 8.8.8.8`. Why is failure the **correct** result here?"*

Then take/confirm a clean **snapshot** (Tier B) of the isolated setup.

Day 5 — Snapshot, document & wrap up

Snapshot your clean lab (Tier B)

1. With Kali clean and isolated: select the VM → **Snapshots** → **Take**.
2. Name it `clean-isolated`.
3. This is your **undo button** — if the VM ever gets owned, restore it.



Screenshot: the Snapshots view showing `clean-isolated`.

Tier A: note in your journal how to **reset/relaunch** the AttackBox instead.

Check your understanding

Your VM gets "owned" during a lab. Fastest way back to known-good?

- A) Reinstall the whole OS
- B) Buy a new computer
- C) Restore your clean snapshot
- D) Switch to bridged networking

Answer

C — restore your clean snapshot.

- No reinstall, no new hardware needed.
- This is why you snapshot **before** anything goes wrong.

Owned? Restore. Seconds later you're clean again.

Write a clean setup journal entry

A good entry includes:

- Which **tier(s)** you used.
- Your attack machine's **IP** and **network mode** (Tier B), or that you used the **AttackBox** (Tier A).
- Your **isolation results**: target ping succeeded; `8.8.8.8` failed.
- What went wrong and how you fixed it ("**Try Harder**" notes).

Day 5 exit ticket

"If your VM ever gets messed up or 'owned,' what's the fastest way back to a clean state?"

Then take the **Unit 02 quiz** and assemble your deliverable.

Full vocabulary (1 of 2)

Term	Meaning
Virtual machine (VM)	A whole computer running as software inside your real one
Host / Guest	Your real machine / the VM running on it
Hypervisor	The software that runs VMs (VirtualBox)
Kali Linux	Free Linux distro loaded with pentest tools — the attack workstation
Distribution (distro)	A version of Linux bundled with particular software
Snapshot	A saved VM state you can instantly restore
Sandbox	An isolated, safe environment made for experimenting

Full vocabulary (2 of 2)

Term	Meaning
Network isolation	Keeping the lab on its own network, sealed off
Host-Only adapter	VM talks to host + lab VMs, not the internet
Internal network	VM talks only to other lab VMs
Bridged	VM on the real network — never for attacks
NAT	VM gets internet via host — not for attacks (updates only)
IP address / <code>ping</code>	Numeric network address / command to test reachability
AttackBox / Room	Browser Kali machine / a guided THM lesson



Lab safety & authorization

reminder

You may only run offensive techniques inside the approved, isolated lab — and only after your AUP is **signed by you and your guardian** and on file. Never use these techniques against any system you don't own or have **written permission** to test — the school, classmates, or any website. **Minors are not exempt.** This unit's whole point: make sure your lab **cannot reach anything it shouldn't.**

Lab walk-through summary

- **Part A (Tier A):** account → launch AttackBox → work an intro room.
- **Part B (Tier B):** import Kali → set **Host-Only** → boot → `ip a` → start target.
- **Part C (everyone): verify isolation** — target ping , `8.8.8.8`  fails.
- **Part D (everyone):** snapshot `clean-isolated` + write the journal entry.

Lab deliverables

Tier A: logged-in dashboard, loaded AttackBox, intro room with completed tasks.

Tier B: Host-Only network settings, Kali's IP (`ip a`), successful target ping, **failed** `ping 8.8.8.8`, and the `clean-isolated` snapshot.

Everyone: a lab-journal entry with the safety reminder at the top.

Recap

- **VMs** are safe, resettable, isolatable computers-in-software; **Kali** is the attack workstation.
- **Snapshots** are your undo button.
- Three tiers: **A browser, B local VMs, C wargames.**
- **Isolation** keeps "authorized" honest. **Host-Only/Internal** for attacks; **never Bridged/NAT.**
- **Verify** it: target ping succeeds, `ping 8.8.8.8` **fails** — and that failure is the win.

Exit ticket & discussion

1. Why is verifying isolation an **ethical** step, not just a technical one?
2. A classmate's Kali is set to **Bridged** and about to start an attack lab — what do you tell them, and what should they do instead?
3. Your VM gets "owned" mid-lab. Fastest way back to known-good?

Submit: screenshot proof of a working, isolated lab + your lab-journal entry.